

Relatório de Progresso

Plataforma SaaS multitenant para campanhas eleitorais — o que foi construído, testado e está em produção de staging até 13 de julho de 2026.

Módulos entregues e testados	Módulo 1 (Tabelas/Cadastros) · Módulo 2 (Campanha)
Tabelas no banco	15 tabelas de produto, todas com isolamento por campanha (RLS)
Migrations aplicadas	10 (0001 a 0010), todas testadas contra Postgres real
Testes automatizados de segurança	54 verificações de RLS, 100% passando
Telas construídas	11 rotas — login, onboarding, MFA, usuários, base de conhecimento, monitoramento, concorrentes, demandas
Bugs reais encontrados e corrigidos	11, todos durante teste real (não só leitura de código)

Este relatório documenta o trabalho de uma sessão contínua de desenvolvimento, seguindo disciplina de Planejador → Programador → Testador registrada em `.pipeline/` a cada entrega. Todo teste de segurança citado aqui rodou contra um banco Postgres/Supabase real (staging), não é leitura de código nem simulação.

1. Arquitetura

Modelo: SaaS multitenant. Cada campanha (candidato) é um tenant isolado; `campanha_id` é a raiz de isolamento de todo o schema.

Banco: Postgres via Supabase, com Row Level Security (RLS) **forçada** em toda tabela sensível — isolamento garantido no banco, não só por filtro na aplicação.

Storage: dois buckets privados (base-conhecimento e monitoramento), com policies de acesso que reaproveitam as mesmas funções de isolamento por tenant usadas nas tabelas.

Frontend: Next.js (App Router) + TypeScript + Tailwind, em `apps/web/`. Autenticação via Supabase Auth, com MFA (TOTP) obrigatório para os papéis de maior privilégio.

Por que isso importa: um vazamento de dado entre campanhas é simultaneamente risco jurídico (LGPD) e risco comercial fatal (cliente vendo dado do concorrente). Por isso todo isolamento foi testado contra banco real, papel por papel, não assumido como "deve funcionar".

2. Estrutura de módulos

Módulo	Nome	Status
1	Tabelas e Cadastros	Pronto e testado
2	Campanha (base de conhecimento, monitoramento, concorrentes, demandas)	Pronto e testado
3	Jurídico (conformidade/rotulagem IA, escudo antideepfake, matriz de alertas)	Não iniciado
4	Marketing (antigo "Relacionamento": enquête, demanda formal, embaixadores, mandato)	Não iniciado

Reorganização feita a pedido do usuário: o antigo "Módulo 2 — Jurídico / Módulo 3 — Relacionamento" virou Módulo 3 e 4, abrindo espaço para o Módulo 2 (Campanha) — o repositório de conhecimento e inteligência que os módulos de conteúdo vão consultar depois.

3. Módulo 1 — Tabelas e Cadastros

[PRONTO E TESTADO] Schema fundacional, hierarquia de papéis, autenticação e telas de gestão.

3.1 Schema multitenant (migrations 0001–0003, 0005–0006)

- 6 tabelas fundação: `campanhas`, `usuarios_internos`, `territorios`, `cidadaos`, `consentimentos_lgpd`, `log_auditoria` — todas com RLS forçada.
- Consentimento do cidadão é imutável: revogação cria novo registro, nunca UPDATE/DELETE do original.
- `log_auditoria` é append-only por trigger — bloqueado mesmo para roles com privilégio de superusuário, testado explicitamente.
- Cadastro de cidadão nunca aceita "importação em massa" — é trava de enum de banco, não só validação de aplicação (não existe o valor "importacao" no tipo).
- Função `bootstrap_campanha()` resolve o problema de ovo-e-galinha: sem ela, ninguém conseguiria criar a primeira campanha nem o primeiro usuário administrador.

3.2 Hierarquia de papéis (migrations 0005–0006)

Papel	Nível	Acesso
Coord. de campanha	Máximo	Leitura e administração total
Candidato	Máximo	Leitura total (inclusive dado de cidadão) — sem poder administrativo
Advogado responsável	Jurídico sênior	Bloco jurídico completo + encaminhamento formal
Assistente jurídico	Jurídico júnior	Bloco jurídico, sem poder de encaminhamento formal
Coord. de marketing	Marketing sênior	Bloco de marketing + edita base de conhecimento
Redator de marketing	Marketing júnior	Cria conteúdo, não edita a base de conhecimento
Embaixador	Campo	Só o próprio território, sem PII de outros territórios

Decisão relevante: o candidato passou a ler tudo (inclusive dado pessoal de cidadão), revertendo a restrição original da especificação — decisão explícita do usuário, sem poder administrativo associado.

3.3 Telas construídas

- **Login / Cadastro** — Supabase Auth (e-mail/senha).
- **Onboarding** — cria a campanha e o primeiro coord_campanha, uma única vez.
- **MFA (TOTP)** — obrigatório pra coord_campanha e candidato: tela de ativação com QR code e fallback de código manual, e tela de verificação a cada novo login.
- **Usuários** — cadastro de território, convite de usuário interno por papel (com criação de conta via API de administração + inserção da linha de acesso respeitando a mesma RLS testada).

4. Módulo 2 — Campanha

[PRONTO E TESTADO] Base de conhecimento, monitoramento, concorrentes e demandas observadas.

4.1 Base de conhecimento (migrations 0004, 0009)

- Conteúdo organizado por **tema** (Biografia, Legislação Eleitoral, Atual Conjuntura, etc.) — cada tema criado livremente pela coordenação.
- Cada item aceita **descrição digitada e/ou arquivo(s) anexado(s)** (PDF via Storage privado).
- Um item aceita **múltiplos arquivos** — não é um único arquivo por item.
- **Editar** corrige título/descrição (substitui). **Adicionar informação** só acrescenta ao final do que já existe, nunca apaga conhecimento já registrado — dois botões, dois comportamentos, por pedido explícito do usuário.
- Edição restrita a coord_campanha e coord_marketing; leitura liberada a todos os papéis internos.

4.2 Monitoramento — menções ao candidato na internet (migrations 0007–0008)

- Ponto único de entrada pra qualquer menção encontrada — não separa jurídico e marketing na captação, porque a mesma menção pode interessar aos dois times.
- 8 categorias: Ameaça jurídica, Deepfake suspeito, Gestão de crise, Menção positiva, Menção neutra, Menção negativa, Oportunidade de marketing, Outro.
- Gravidade (baixa/média/alta) só nas categorias que pedem resposta ativa.
- Registro manual por enquanto (link + print + descrição) — automação via crawler/Google Alerts fica para uma fase futura, registrada como pendência conhecida, não escondida.

4.3 Concorrentes e Demandas observadas (migration 0010)

- **Concorrentes:** nome, partido, pontos fortes, pontos fracos, promessas — análise de oposição.
- **Demandas observadas:** região, cidade, tema, demanda — nota de referência dos assuntos mais recorrentes por território. *Não é o fluxo formal de cidadão-relata/mandato-encaminha* (esse continua planejado como módulo próprio, com status e encaminhamento, dentro do Módulo 4).

5. Disciplina de testes

Cada entrega seguiu o mesmo ciclo: **Planejador** escreve a especificação antes do código (`.pipeline/specs.md`), **Programador** implementa e documenta decisões e desvios (`changes.md`), **Testador** roda verificação real contra o banco (`results.md`) antes de qualquer entrega ser considerada fechada.

Conjunto de teste	Resultado	O que cobre
Módulo 1 — RLS smoke test	13 / 13	Isolamento cross-tenant, papéis, imutabilidade, compliance
bootstrap_campanha	3 / 3	Criação de tenant, bloqueio de segunda chamada, bloqueio anon
Base de conhecimento	8 / 8	Isolamento, papel liberado/bloqueado, Storage
Hierarquia de papéis	9 / 9	Leitura ampliada do candidato, papéis júnior/sênior
Monitoramento	7 / 7	Criação por papel, isolamento, Storage
Base de conhecimento — arquivos	7 / 7	Múltiplos arquivos, edição, exclusão em cascata
Concorrentes / Demandas	7 / 7	Criação por papel, isolamento cross-tenant
TOTAL	54 / 54	100% das verificações de segurança, contra Postgres real

5.1 Bugs reais encontrados e corrigidos

Todos encontrados testando de verdade (navegador + banco real), não por leitura de código:

- **Ovo-e-galinha no bootstrap:** ninguém conseguia criar a primeira campanha — resolvido com função SECURITY DEFINER dedicada.
- **Grant excessivo para anon:** o Supabase concede privilégio total por padrão a toda tabela nova — REVOKE explícito adicionado como segunda camada de defesa.
- **TerritorioForm sem campanha_id:** insert falhava por RLS por faltar um campo no payload do formulário.
- **QR code do MFA renderizado como texto:** a API já devolve uma data URI pronta, não markup SVG cru — corrigido de `dangerouslySetInnerHTML` para `<img>`.
- **Limpeza de fatores MFA nunca rodava:** `listFactors()` só retorna fatores já verificados no campo usado — fatores órfãos se acumulavam a cada tentativa.
- **Data de expiração um dia adiantada:** formatação de data sem fixar fuso UTC.
- **Formulários sem confirmação de sucesso:** ação funcionava mas usuário achava que tinha falhado — corrigido em 4 formulários.
- `window.confirm()` **nas exclusões:** travava a automação de teste e é UX inconsistente — trocado por confirmação inline.

6. O que falta

Item	Descrição
------	-----------

Nível 3 — App do embaixador	Cadastro de cidadão em campo, offline-first (schema já pronto, app ainda não existe)
Módulo 3 — Jurídico	Conformidade/rotulagem IA, escudo antideepfake, matriz de alertas
Módulo 4 — Marketing	Enquete/plano de governo, loop de demanda formal (status + encaminhamento), rede de embaixadores, histórico de mandato
Painéis executivos	Painel do advogado, da coordenação e do candidato (Camada 4 da especificação)
Automação de monitoramento	Google Alerts / crawler — hoje o registro é manual, por decisão explícita do usuário

7. Histórico de commits

Todo o trabalho está versionado em git, em ordem cronológica:

Commit	Mensagem
a8e53c9	constituição do projeto + Módulo 1 (schema multitenant com RLS testado)
edfe092	telas de cadastro (Next.js) + MFA — Nível 1 e 2 do onboarding
8197bf1	base de conhecimento da campanha (temas + itens + upload de PDF)
da1ead7	hierarquia de papéis (Jurídico e Marketing) + leitura total pro candidato
dc7673f	monitoramento (clipping) do candidato na internet — Módulo Campanha
2abdc58	amplia categorias de monitoramento (positiva/negativa/gestão de crise)
15da5fb	fix: adiciona confirmação visual de sucesso nos formulários de criação
2dc1803	editar/excluir item + múltiplos arquivos na base de conhecimento
4807bc0	botão "Adicionar informação" — complementa sem substituir
0a51918	mais 3 bases de conhecimento - Concorrentes, Demandas observadas, Atual Conjuntura